UNIVERSIDAD VERACRUZANA
FACULTAD DE CONTADURIA Y ADMINISTRACION

PROGRAMA EDUCATIVO

Sistemas Computacionales Administrativos

EXPERIENCIA EDUCATIVA

GESTION DE LAS TEC DE INFORMACION

DOCENTE

GUZMAN COUTIÑO HECTOR

TRABAJO

Actividad Políticas de TI

ESTUDIANTE

DOMINGUEZ LOPEZ JORGE ARTURO
DOMINGUEZ RUIZ OSCAR
HERNANDEZ CRUZ NESTOR IRAM
PONTES RUIZ LUIS ALEJANDRO

BLOQUE Y SECCIÓN

704

Xalapa, VER. 27 DE OCTUBRE DE 2026

1. Introducción

La información y los sistemas tecnológicos son activos críticos para una empresa comercial: de ellos dependen las ventas, el control de inventarios, la relación con proveedores y la confianza de los clientes. Sin reglas claras, los recursos de TI se convierten en una fuente de riesgos legales, financieros y operativos.

La organización ha detectado prácticas que ponen en riesgo su operación: contraseñas compartidas, instalación de software sin autorización, información confidencial en dispositivos personales, ausencia de reglas para correo, internet y nube, incidentes por correos fraudulentos, datos personales sin procedimientos de protección y falta de políticas de respaldo, permisos e incidentes.

Este manual, elaborado por un equipo de consultoría tecnológica a solicitud de la Dirección, establece reglas, responsabilidades y procedimientos para atender dichos problemas, alineados con las disposiciones legales mexicanas aplicables y con marcos de referencia reconocidos. Contiene un catálogo de ocho políticas y el desarrollo completo de dos de ellas (control de acceso y respaldos).

Objetivo del manual

Promover la seguridad de la información, el uso responsable de los recursos tecnológicos, el cumplimiento normativo y la continuidad de las operaciones de la organización.

2. Descripción de la organización seleccionada

La organización seleccionada es una empresa comercial (caso práctico) que opera una cadena de tiendas físicas y un canal de venta en línea. Administra ventas, inventarios, compras a proveedores, facturación y relación con clientes mediante un sistema ERP/CRM. Su personal se compone de áreas de tienda, almacén, ventas, compras, finanzas, recursos humanos, TI y dirección.

Aspecto	Descripción
Giro	Comercialización de productos al menudeo y en línea
Sistemas clave	ERP/CRM, punto de venta (POS), facturación electrónica, correo y almacenamiento en la nube
Información crítica	Datos personales de clientes y empleados, información financiera, precios, inventarios, contratos con proveedores
Pagos	Aceptación de tarjetas y transferencias (posible exigencia contractual PCI DSS)
Áreas usuarias	Tiendas, almacén, ventas, compras, finanzas, RR. HH., TI, dirección

3. Diagnóstico de riesgos tecnológicos

3.1 Recursos tecnológicos

Categoría	Recursos identificados
Hardware	Computadoras de oficina, terminales POS, servidores (locales o virtuales), dispositivos móviles, equipos de red (routers, switches, Wi-Fi), impresoras.
Software	Sistemas operativos, ERP/CRM, POS, suite ofimática, antivirus, herramientas de facturación y plataformas de comercio electrónico.
Información	Datos personales de clientes y empleados, información financiera y fiscal, inventarios, contratos, documentos institucionales.
Usuarios	Empleados de tienda y oficina, administradores de TI, directivos, proveedores y clientes.
Servicios tecnológicos	Internet, correo electrónico, almacenamiento en la nube, sistemas de información y conexiones remotas.

3.2 Tabla de diagnóstico

Problema identificado	Riesgo para la organización	Política requerida
Contraseñas compartidas	Acceso no autorizado; sin trazabilidad de operaciones	POL-TI-02 Control de acceso y contraseñas
Instalación de software sin autorización	Riesgo legal (derechos de autor), malware y fallas	POL-TI-03 Uso aceptable de equipos y software
Dispositivos personales con información confidencial	Fuga o pérdida de información; incumplimiento normativo	POL-TI-06 Nube y dispositivos móviles; POL-TI-03
Sin reglas de correo, internet y nube	Uso indebido, fuga de datos y exposición a amenazas	POL-TI-05 Correo e internet; POL-TI-06

Problema identificado	Riesgo para la organización	Política requerida
Correos fraudulentos (phishing)	Robo de credenciales; fraudes en pagos y datos bancarios	POL-TI-05 Correo e internet; POL-TI-08 Capacitación
Datos personales sin procedimientos de protección	Incumplimiento de la ley de datos personales; sanciones y daño reputacional	POL-TI-04 Protección y privacidad de datos
Sin respaldos, permisos ni respuesta a incidentes	Pérdida de información, paro de ventas, respuesta desordenada	POL-TI-07 Respaldos; POL-TI-01; POL-TI-02

4. Marco legal y reglamentario

Se distinguen las disposiciones obligatorias por ley, las exigibles por contrato o regulación y los marcos de buenas prácticas. Se recomienda verificar la vigencia de cada texto en la fuente oficial (DOF) antes de su aplicación. Fuentes de apoyo sobre la nueva ley de datos personales: EY México y Basham.

Disposición	Versión / fecha	Ámbito y relación con la gestión de TI	Obligación o medida relevante	Fuente
Ley Federal de Protección de Datos Personales en Posesión de los Particulares (nueva ley)	Publicada en el DOF el 20-mar-2025; vigente desde el 21-mar-2025; abroga la ley de 2010	Obligatoria para empresas privadas que tratan datos de clientes y empleados. La autoridad es la Secretaría Anticorrupción y Buen Gobierno (funciones antes del INAI).	Aviso de privacidad Tratar datos solo para las finalidades informadas Medidas de seguridad y confidencialidad Atender derechos ARCO	DOF

Disposición	Versión / fecha	Ámbito y relación con la gestión de TI	Obligación o medida relevante	Fuente
Ley General de Protección de Datos Personales en Posesión de Sujetos Obligados	DOF 20-mar-2025	Aplica al sector público. No aplica directamente a una empresa privada; se incluye para distinguir ámbitos.	Solo como referencia comparativa.	DOF
Ley Federal del Derecho de Autor	Texto vigente (Cámara de Diputados)	Los programas de cómputo son obras protegidas (arts. 101 a 114).	Usar solo software con licencia Controlar copias e instalaciones	Diputados
Código Penal Federal	Texto vigente; arts. 211 bis 1 y ss.	Sanciona acceso ilícito, modificación o destrucción de información en sistemas.	Prohibir accesos no autorizados Usar cuentas individuales y registros	Diputados
Ley Federal del Trabajo	Texto vigente	Obligaciones del personal con herramientas e información (art. 134) y causas de rescisión (art. 47), base de las medidas disciplinarias.	Reglamento interior con reglas de uso de TI Consecuencias proporcionales	Diputados
Contratos, licencias y NDA	Según cada contrato	Condiciones de uso de software, servicios en la nube e información confidencial.	Cumplir licencias y SLA Acuerdos de confidencialidad	Contratos internos

Disposición	Versión / fecha	Ámbito y relación con la gestión de TI	Obligación o medida relevante	Fuente
			con personal y terceros	
PCI DSS (si se procesan tarjetas)	Versión vigente del PCI SSC	Exigible por contrato con adquirentes y marcas de pago.	Proteger datos de tarjeta Control de acceso y monitoreo	PCI SSC

5. Normas y marcos de referencia

Son marcos voluntarios de buenas prácticas; solo resultan exigibles si un contrato, cliente o regulación lo requiere.

Norma / marco	Versión	Ámbito	Aplicación en la organización	Fuente
ISO/IEC 27001	2022	Sistema de gestión de seguridad de la información (SGSI)	Estructura general del manual, gestión de riesgos y mejora continua	ISO
ISO/IEC 27002	2022	Catálogo de controles de seguridad	Controles de acceso, respaldos, criptografía, proveedores y capacitación	ISO
ISO/IEC 20000-1	2018	Gestión de servicios de TI	Gestión de incidentes, cambios y niveles de servicio	ISO
COBIT	2019	Gobierno y gestión de TI	Alinear TI con objetivos del negocio, roles e indicadores	ISACA

Norma / marco	Versión	Ámbito	Aplicación en la organización	Fuente
ITIL	Versión 4	Prácticas de gestión de servicios	Mesa de ayuda, incidentes y gestión de cambios	PeopleCert

6. Catálogo de ocho políticas de gestión de TI

POL-TI-01 · Seguridad de la información

Propósito	Proteger la confidencialidad, integridad y disponibilidad de la información de la organización.
Alcance	Toda la información, sistemas y personal, incluidos proveedores.
Responsables	Dirección General (aprueba); TI/Seguridad (opera); dueños de información.
Reglas de cumplimiento	Clasificar la información: pública, interna, confidencial, restringida. Todo incidente se reporta en máx. 1 h al canal de TI. Información confidencial solo en sistemas autorizados y cifrados.
Seguimiento	Número de incidentes y tiempo de contención; revisión semestral.

POL-TI-02 · Control de acceso y contraseñas

Propósito	Evitar accesos no autorizados y asegurar trazabilidad de acciones.
Alcance	Usuarios del ERP/CRM, correo, nube, equipos y redes.
Responsables	TI (administra); jefes de área (solicitan); usuarios (custodian).
Reglas de cumplimiento	Cuenta individual; prohibido compartir contraseñas. MFA en accesos remotos, privilegiados, correo y ERP.

	Privilegio mínimo por rol; baja de accesos en máx. 24 h.
Seguimiento	Revisión trimestral de cuentas; % usuarios con MFA.

POL-TI-03 · Uso aceptable de equipos y software

Propósito	Asegurar el uso lícito, seguro y responsable de equipos y programas.
Alcance	Equipos de tienda, oficinas, servidores y móviles institucionales o personales con acceso a datos.
Responsables	TI (autoriza y licencia); usuarios; Compras (contratos).
Reglas de cumplimiento	Solo software autorizado y con licencia en el catálogo oficial. Prohibido instalar software por cuenta propia. Dispositivos personales (BYOD) solo con registro, cifrado y MDM.
Seguimiento	Inventario trimestral de software y hardware; hallazgos de software no autorizado = 0.

POL-TI-04 · Protección y privacidad de datos personales

Propósito	Cumplir la normativa de datos personales de clientes, empleados y proveedores.
Alcance	Bases de datos, ERP/CRM, expedientes, formatos y encargados externos.
Responsables	Responsable de datos personales; TI; Jurídico; RR. HH.; Ventas.
Reglas de cumplimiento	Aviso de privacidad vigente en cada punto de captura. Tratar datos solo para las finalidades informadas. Plazos de conservación y eliminación segura documentados. Contratos con terceros que traten datos (encargados).

Seguimiento	Inventario de datos; atención de derechos ARCO en plazo; auditoría anual.

POL-TI-05 · Correo electrónico e internet

Propósito	Reducir fraudes por phishing y regular el uso de comunicación y navegación.
Alcance	Correo institucional, navegación y mensajería de todo el personal.
Responsables	TI (filtros, antispam); usuarios; Capacitación.
Reglas de cumplimiento	Correo institucional solo para fines laborales; prohibido el personal para datos de la empresa. No abrir enlaces ni adjuntos sospechosos; reportar al buzón de TI. Verificar por otro canal solicitudes de pagos o cambios de datos bancarios.
Seguimiento	Simulacros de phishing trimestrales; tasa de clics y de reporte.

POL-TI-06 · Servicios en la nube y dispositivos móviles

Propósito	Usar la nube y los móviles de forma segura y controlada.
Alcance	Plataformas SaaS/IaaS, almacenamiento y móviles con acceso a información.
Responsables	TI (aprueba plataformas); Jurídico (contratos/SLA); usuarios.
Reglas de cumplimiento	Solo plataformas aprobadas; prohibidas cuentas personales para información de la empresa. Compartir archivos con permisos mínimos y caducidad de enlaces. Bloqueo de pantalla, cifrado y borrado remoto en móviles.

Seguimiento	Catálogo de servicios aprobados; revisión semestral de permisos compartidos.

POL-TI-07 · Respaldos y continuidad operativa

Propósito	Garantizar la recuperación de información y servicios críticos ante fallas o ataques.
Alcance	ERP/CRM, inventarios, ventas, facturación, bases de clientes y servidores.
Responsables	TI (respaldos); Dirección (plan de continuidad); dueños de procesos.
Reglas de cumplimiento	Regla 3-2-1 con cifrado y copia fuera de sitio o inmutable. Definir RPO y RTO por sistema crítico. Pruebas de restauración documentadas.
Seguimiento	% de respaldos exitosos; pruebas trimestrales; cumplimiento de RTO/RPO.

POL-TI-08 · Cumplimiento, auditoría y capacitación

Propósito	Verificar el cumplimiento de las políticas y fortalecer la cultura de seguridad.
Alcance	Todo el personal, áreas y proveedores críticos.
Responsables	Comité de TI; Auditoría interna; RR. HH.; Dirección.
Reglas de cumplimiento	Capacitación de inducción y anual obligatoria. Revisión periódica de accesos, registros e incidentes. Plan de acciones correctivas con fechas y responsables.
Seguimiento	% personal capacitado ≥ 95 %; auditoría semestral; revisión anual del manual.

7. Desarrollo detallado de dos políticas

POL-TI-02 · Política de control de acceso y uso de contraseñas

Elemento	Descripción
Nombre de la política	Política de control de acceso y uso de contraseñas
Código y versión	POL-TI-02 · Versión 1.0 · Octubre de 2026
Objetivo	Reducir el riesgo de accesos no autorizados a los sistemas de la organización y asegurar que cada acción pueda atribuirse a una persona.
Alcance	Todos los usuarios (empleados, directivos, proveedores) que accedan al ERP/CRM, POS, correo, nube, equipos y redes de la organización.
Fundamento	Nueva LFPDPPP (medidas de seguridad); Código Penal Federal (acceso ilícito); Ley Federal del Trabajo; ISO/IEC 27001 y 27002 (control de acceso); COBIT.
Responsables	TI: administra identidades, MFA y registros. Jefes de área: solicitan altas, cambios y bajas. Usuarios: protegen sus credenciales y reportan incidentes. Responsable de datos personales y Dirección: supervisan.
Reglas de uso	Permitido: cuenta individual; gestor de contraseñas aprobado; acceso según el rol. Restringido: cuentas privilegiadas con aprobación y registro; accesos remotos solo con MFA; contraseñas de mínimo 12 caracteres. Prohibido: compartir contraseñas o cuentas; anotarlas en papel o chats; usar cuentas de otra persona; dejar sesiones abiertas.

Elemento	Descripción
Procedimiento	Alta: el jefe solicita por el sistema de tickets y TI asigna permisos mínimos. Cambios de puesto: se revisan permisos. Baja: RR. HH. avisa a TI y se desactivan accesos en máx. 24 h. Incumplimiento o sospecha: reportar de inmediato a TI para bloquear la cuenta, cambiar claves y revisar registros.
Seguimiento	Indicadores: 0 cuentas compartidas; % usuarios con MFA ≥ 95 %; bajas atendidas en 24 h. Evidencias: tickets, registros de acceso y actas de revisión. Frecuencia: revisión trimestral de cuentas activas y privilegiadas.
Consecuencias	Medidas correctivas proporcionales conforme al reglamento interior de trabajo y a la Ley Federal del Trabajo; si hay delito, se evalúan acciones legales.

POL-TI-07 · Política de respaldos y continuidad operativa

Elemento	Descripción
Nombre de la política	Política de respaldos y continuidad operativa
Código y versión	POL-TI-07 · Versión 1.0 · Octubre de 2026
Objetivo	Garantizar que la información y los servicios críticos de la organización puedan recuperarse ante fallas, errores, ransomware o desastres.
Alcance	ERP/CRM, POS, inventarios, facturación, bases de clientes, servidores, correo y almacenamiento en la nube.
Fundamento	Nueva LFPDPPP (disponibilidad y seguridad de datos); ISO/IEC 27002 (respaldos y continuidad); ISO/IEC 20000-1; COBIT.
Responsables	TI: ejecuta y monitorea respaldos y restauraciones. Dirección: aprueba el plan de continuidad y recursos. Dueños de procesos: definen la criticidad, RPO y RTO, y validan las restauraciones.
Reglas de uso	Permitido: guardar información en repositorios institucionales respaldados. Restringido: acceso a respaldos solo para personal autorizado; copias cifradas y fuera de sitio. Prohibido: almacenar información crítica solo en equipos personales o USB; desactivar o eliminar respaldos.
Procedimiento	Respaldo diario incremental y semanal completo, con regla 3-2-1. Registro automático de resultado; fallas se atienden como incidente. Prueba de restauración trimestral con acta.

Elemento	Descripción
	Plan de continuidad: roles, contactos, orden de recuperación y operación manual de tiendas.
Seguimiento	Indicadores: % respaldos exitosos ≥ 98 %; pruebas de restauración realizadas; cumplimiento de RTO/RPO. Evidencias: bitácoras, actas de pruebas. Frecuencia: revisión mensual de bitácoras; plan revisado anualmente.
Consecuencias	Incumplimientos se registran como hallazgo; medidas correctivas conforme al reglamento interior y a la normativa laboral aplicable.

8. Responsables e indicadores de cumplimiento

Rol	Responsabilidades
Dirección General	Aprobar el manual, asignar recursos y revisar resultados.
Comité de TI	Dar seguimiento al cumplimiento, riesgos e incidentes.
Área de TI	Implementar controles, administrar accesos, respaldos y atender incidentes.
Responsable de datos personales	Aviso de privacidad, derechos ARCO y contratos con encargados.
Jurídico y RR. HH.	Contratos, reglamento interior, medidas disciplinarias y capacitación.
Jefes de área	Solicitar accesos y vigilar el cumplimiento de su equipo.
Usuarios	Cumplir las políticas, proteger credenciales y reportar incidentes.

9. Conclusiones

Los problemas de la organización (contraseñas compartidas, software no autorizado, datos en dispositivos personales, phishing, falta de protección de datos y de respaldos) se deben principalmente a la ausencia de reglas y responsabilidades claras, más que a la falta de tecnología.

Las ocho políticas propuestas atienden cada riesgo identificado, se fundamentan en la legislación mexicana aplicable (en particular la nueva ley de datos personales vigente desde marzo de 2025) y se apoyan en ISO/IEC 27001 y 27002, ISO/IEC 20000-1, COBIT e ITIL.

Su eficacia dependerá de la aprobación de la Dirección, de la capacitación continua, de medir los indicadores definidos y de revisar el manual al menos una vez al año, conforme al principio de mejora continua.

Caso de aplicación: para efectos de este ejercicio, el modelo se ilustra con una empresa ficticia denominada ComerMex, S.A. de C.V., que puede sustituirse por la organización que se desee.

10. Referencias bibliográficas y fuentes oficiales consultadas

Diario Oficial de la Federación. Decreto por el que se expide la Ley Federal de Protección de Datos Personales en Posesión de los Particulares, 20 de marzo de 2025. Consultar en: https://www.dof.gob.mx

EY México (2025). Entrada en vigor de la nueva Ley Federal de Protección de Datos Personales en Posesión de los Particulares. https://www.ey.com/es_mx/technical/tax/boletines-fiscales/nueva-ley-federal-proteccion-datos-personal-posesion-particulares

Basham (2025). Nueva Ley Federal de Protección de Datos Personales en Posesión de los Particulares publicada en el DOF. https://basham.com.mx/nueva-ley-federal-de-proteccion-de-datos-personales-en-posesion-de-los-particulares/

Cámara de Diputados. Ley Federal del Derecho de Autor. https://www.diputados.gob.mx/LeyesBiblio/pdf/LFDA.pdf

Cámara de Diputados. Código Penal Federal. https://www.diputados.gob.mx/LeyesBiblio/pdf/CPF.pdf

Cámara de Diputados. Ley Federal del Trabajo. https://www.diputados.gob.mx/LeyesBiblio/pdf/LFT.pdf

ISO/IEC 27001:2022. Information security management systems. https://www.iso.org/standard/27001

ISO/IEC 27002:2022. Information security controls. https://www.iso.org/standard/75652.html

ISO/IEC 20000-1:2018. Service management system requirements. https://www.iso.org/standard/70636.html

ISACA. COBIT 2019 Framework. https://www.isaca.org/resources/cobit

PeopleCert / AXELOS. ITIL 4. https://www.peoplecert.org

PCI Security Standards Council. PCI DSS. https://www.pcisecuritystandards.org